



CSC432 – INFORMATION SECURITY

Dr. Muhammad Sharjeel

muhammadsharjeel@cuilahore.edu.pk



Lecture No 2

COMPUTER SECURITY – FIRST CONCEPTS

Something to worry about



- ☐ Are some of the attempts to deal with cybersecurity damaging liberty?
- ☐ Does data mining for terrorists and criminals pose a threat to ordinary people?
- ☐ The NSA is looking at a lot of stuff (and they aren't the only ones)
- ☐ Can I trust Facebook/Google/Twitter/Skype/'YouNameIt' with my private information?
- ☐ Are we in danger of losing all privacy?

Something to worry about



Trust

- ☐ An extremely important security concept
 - ☐ You do certain things for those you trust
 - ☐ You don't do them for those you don't
- ☐ Seems simple, ???
- ☐ Problems with trust
 - ☐ How do you express trust?
 - ☐ Why do you trust something?
 - ☐ How can you be sure who you're dealing with?
 - ☐ What if trust is situational?
 - ☐ What if trust changes?

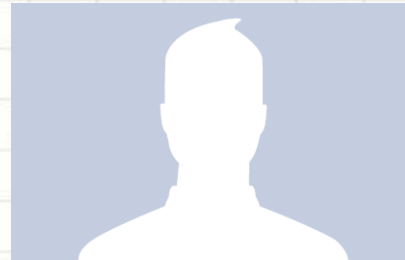
Something to worry about



Transitive Trust



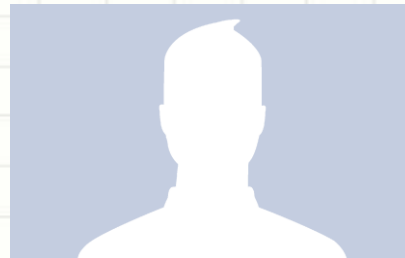
I trust Barbara



Barbara trust Andy



David trust Carol



Andy trust David

- ☐ So do I trust Carol?
- ☐ Should I?

Absolute Security vs Absolute Access



- ❑ It's very important to understand that in security, one simply cannot say ``what's the best firewall?''
- ❑ There are two extremes: absolute security and absolute access
- ❑ The closest we can get to an absolutely secure machine is one unplugged from the network, powered off, locked in a safe
- ❑ Unfortunately, it isn't terribly useful in this state

Absolute Security vs Absolute Access



- ❑ A machine with absolute access is extremely convenient to use: it's simply there, and will do whatever you tell it, without questions, authorization, passwords, or any other mechanism
- ❑ Unfortunately, this isn't terribly practical, either
- ❑ The internet is a bad neighborhood now, and it isn't long before some bonehead will tell the computer to do something like self-destruct, after which, it isn't terribly useful to you

Computer Security – First Concepts



- ☐ Security thus depends on the policies we define and the decisions we take
- ☐ This is no different from our daily lives
- ☐ We constantly make decisions about what risks we're willing to accept
- ☐ When we get in a car and drive to work, there's a certain risk that we're taking
- ☐ It's possible that something completely out of control will cause us to become part of an accident on the highway
- ☐ When we get on an airplane, we're accepting the level of risk involved as the price of convenience

Computer Security – First Concepts



- ☐ However, we have a mental picture of what an acceptable risk is, and won't go beyond that in most circumstances
- ☐ If I happen to be upstairs at home, and want to leave for work, I'm not going to jump out the window
- ☐ Yes, it would be more convenient, but the risk of injury outweighs the advantage of convenience

Computer Security – First Concepts



- ❑ Every organization needs to decide for itself where between the two extremes of total security and total access they need to be
- ❑ A policy needs to articulate this, and then define how that will be enforced with practices and such
- ❑ Everything that is done in the name of security, then, must enforce that policy uniformly

Computer Security – First Concepts



- ☐ Cost benefit analysis – A use case
- ☐ A database that provides salary information to a second system that print checks
 - ☐ Huge financial loss
- ☐ A company has several branch offices and each downloads the database copy daily
- ☐ The branch office uses the database to recommend the salary, but the main office use the original database for the final calculations
 - ☐ Recoverable !

Computer Security – First Concepts



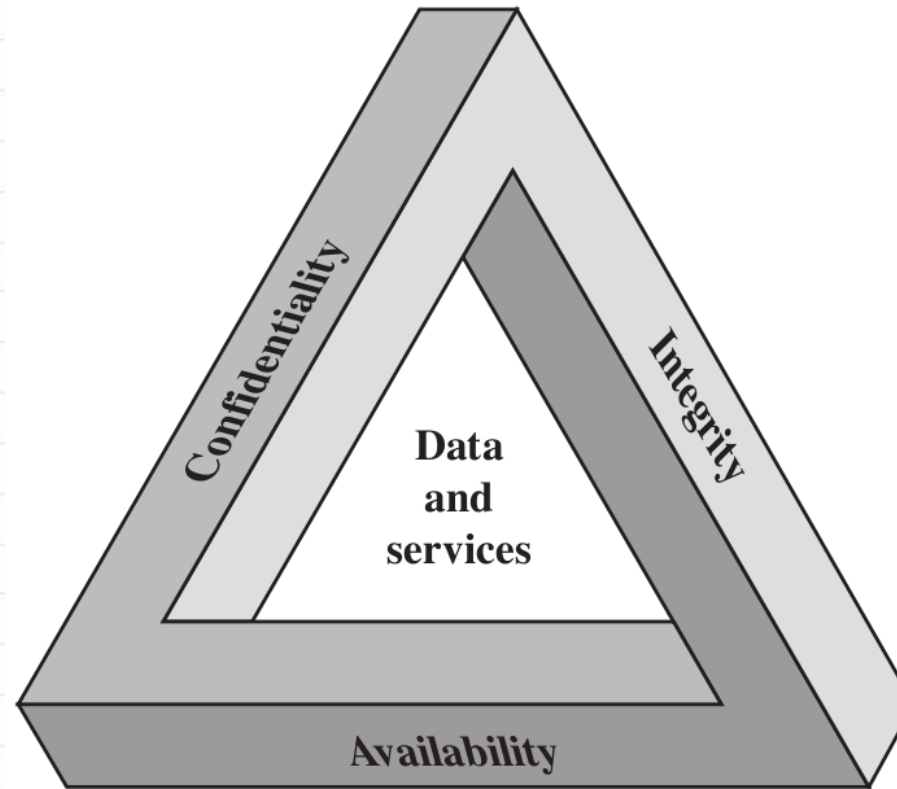
- ❑ Some rational thinking!
- ❑ Consider a company where 10000 documents are processed per month with no security mechanism
- ❑ Security breaches occur about twice per month, and almost 100 documents are compromised per breach
 - ❑ The administrator needs to restart the processing of the breached documents
- ❑ Each document's processing worth about 2000, and the documents compromised tend to be about half processed when they are restarted
- ❑ If some security mechanism is installed, it will increase the average processing cost about 1% for all the documents
- ❑ Should the company install security mechanism?

Key Security Concepts



Security Goals (the CIA triad)

- ☐ Confidentiality
- ☐ Integrity
- ☐ Availability



Key Security Concepts

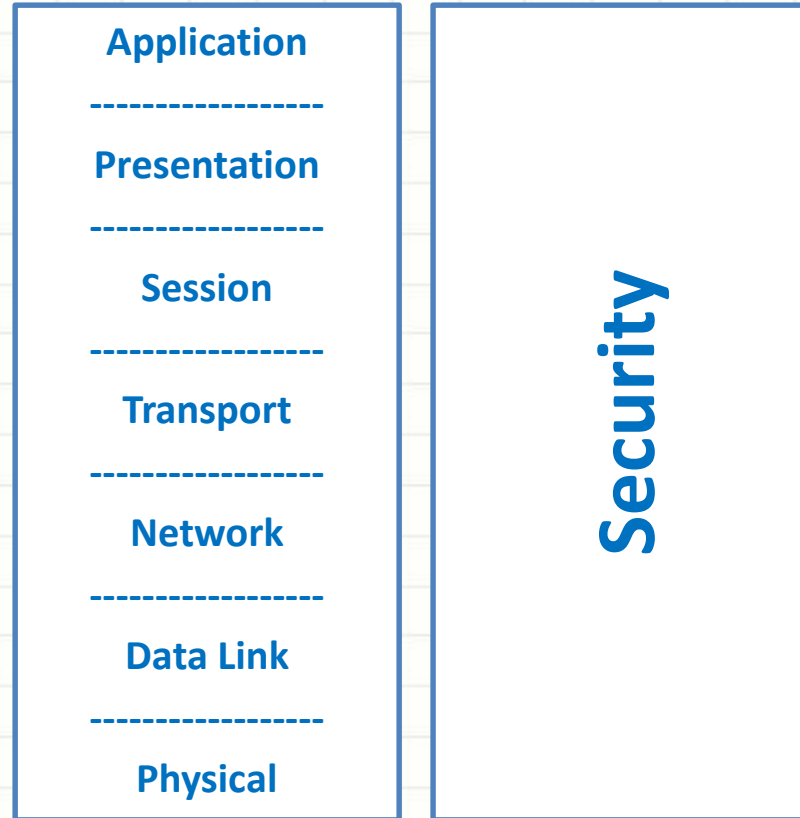


- ❑ **Confidentiality:** only sender, intended receiver should “understand” message contents
 - ❑ covers both data confidentiality and privacy
- ❑ **Integrity:** sender, receiver want to ensure message not altered (in transit, or afterwards) without detection, and want to be able to prove that the sender did, in fact, send the message
 - ❑ covers both data and system integrity
- ❑ **Availability:** services must be accessible and available to properly authorized users
 - ❑ Ensuring timely and reliable access to and use of information

Key Security Concepts



Networking Basics



Key Security Concepts



The OSI Security Architecture

- ❑ ITU-T X.800 Security Architecture for OSI
- ❑ Systematic approach to define requirements for security and approaches to satisfying those requirements
- ❑ For us, it provides a useful, if abstract, overview of concepts we will study
- ❑ Security aspects: **Attacks, mechanisms and services**

Key Security Concepts



Aspects of Security

☐ **Security Attack**

- ☐ Any action that attempts to compromise the security of information or facilities (own by an organization)
- ☐ Threat: potential for violation of security of information or facilities

☐ **Security Mechanism**

- ☐ A method (process) for preventing, detecting or recovering from an attack

☐ **Security Service**

- ☐ A communication/processing service that enhances the security of a system Uses multiple mechanisms to ensure safety from a single attack, like one mechanism if bypassed then another and so on.
- ☐ The services are intended to counter security attacks.
- ☐ They make use of security mechanisms to provide the service

Key Security Concepts



Types of Attacks

Passive Attack

- ☐ Make use of information, but not affect system resources, e.g.
 - ☐ Release message contents
 - ☐ Traffic analysis
- ☐ Relatively hard to detect, but easier to prevent

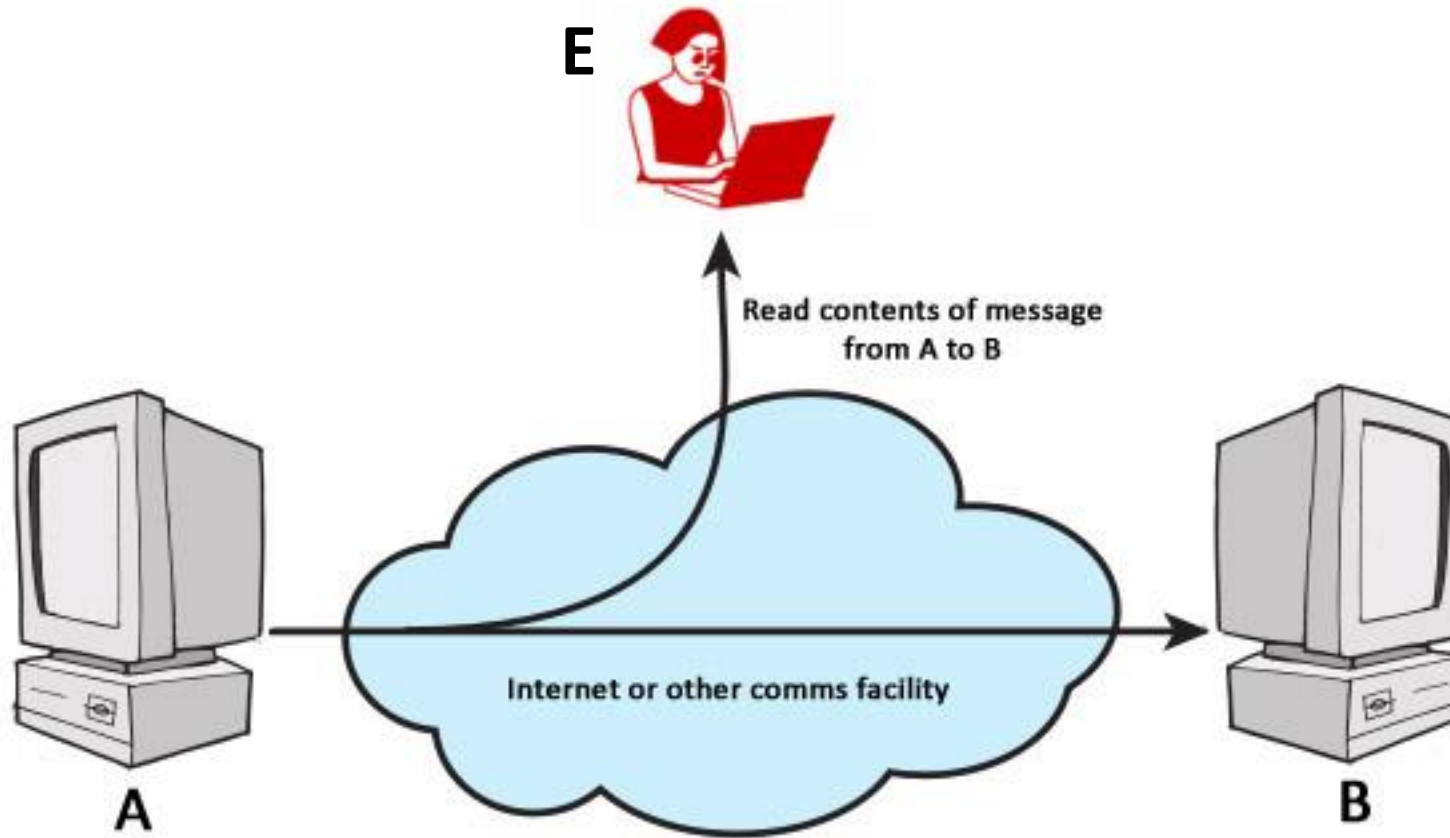
Active Attack

- ☐ Alter system resources or operation, e.g.
 - ☐ Masquerade
 - ☐ Replay
 - ☐ Modification
 - ☐ Denial of service
- ☐ Relatively hard to prevent, but easier to detect

Key Security Concepts



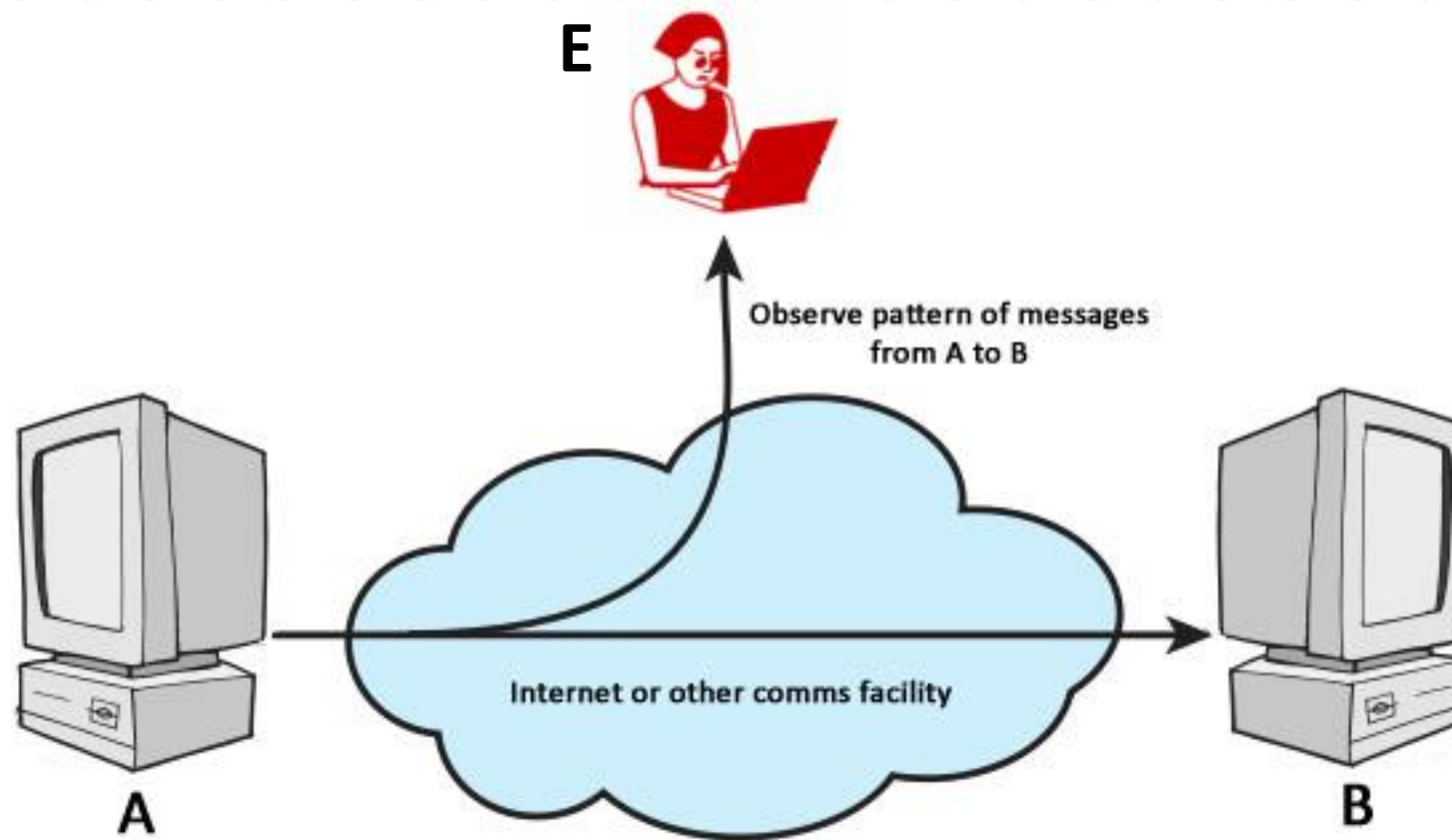
Release message contents – Passive Attack



Key Security Concepts



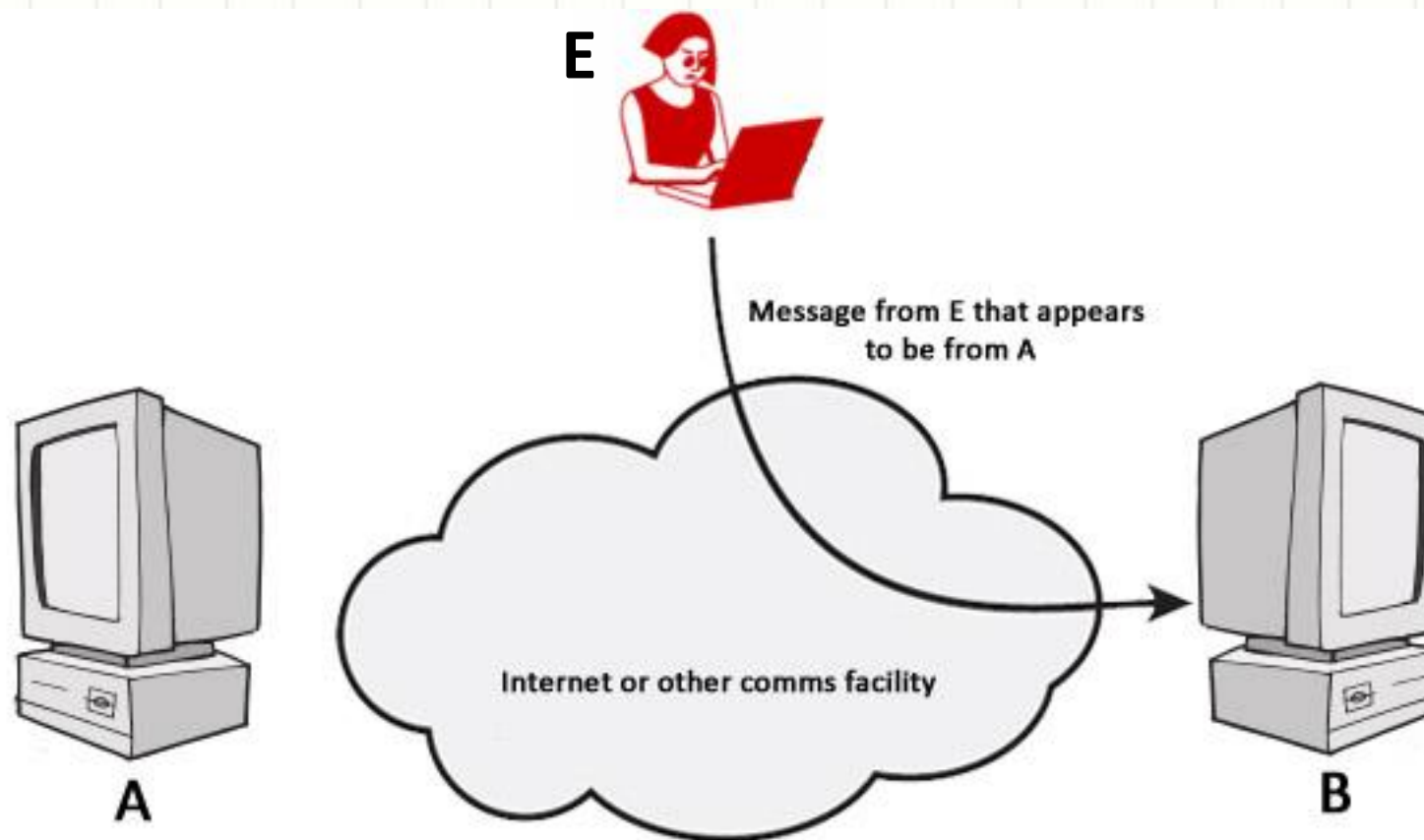
Traffic analysis – Passive Attack



Key Security Concepts



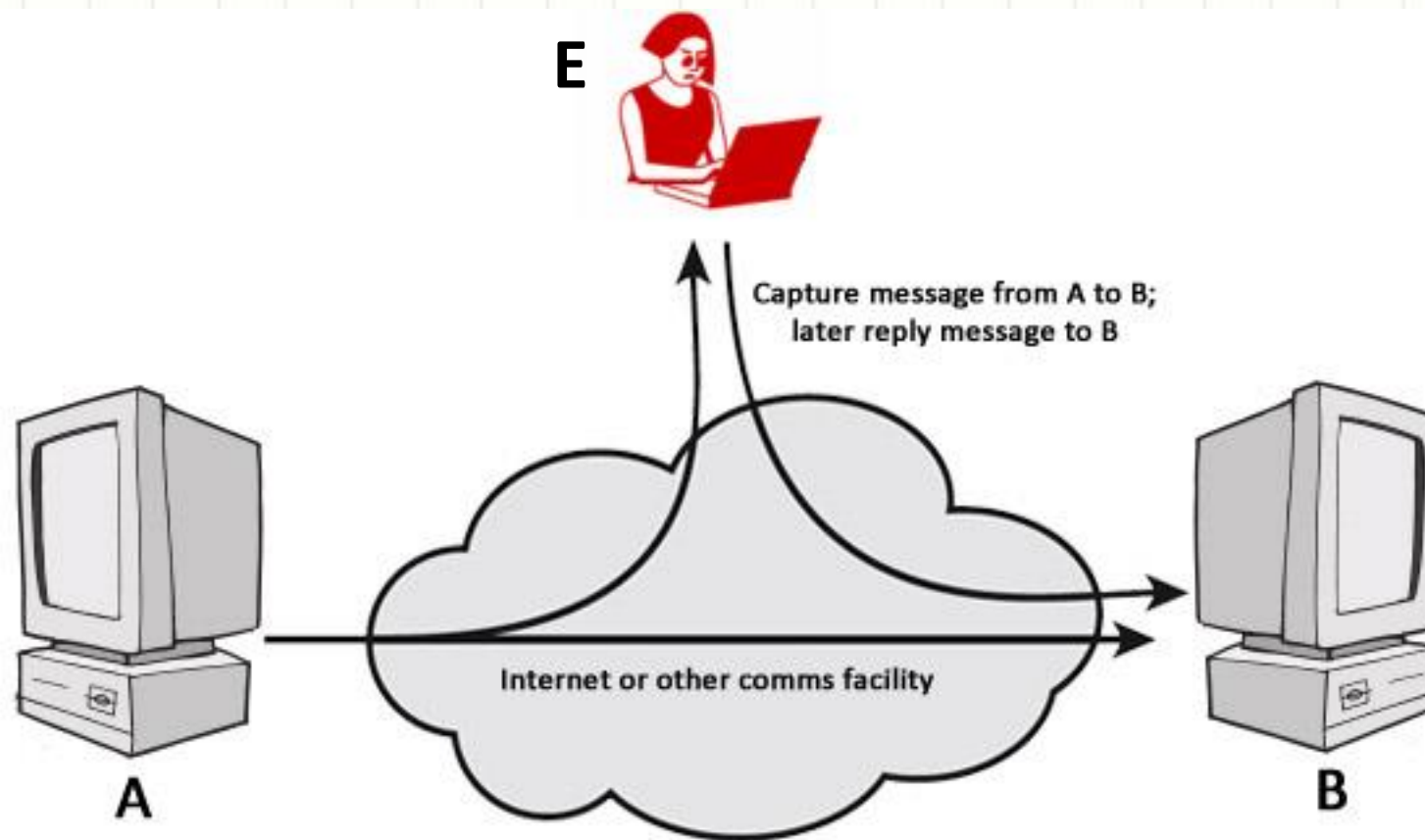
Masquerade – Active Attack



Key Security Concepts



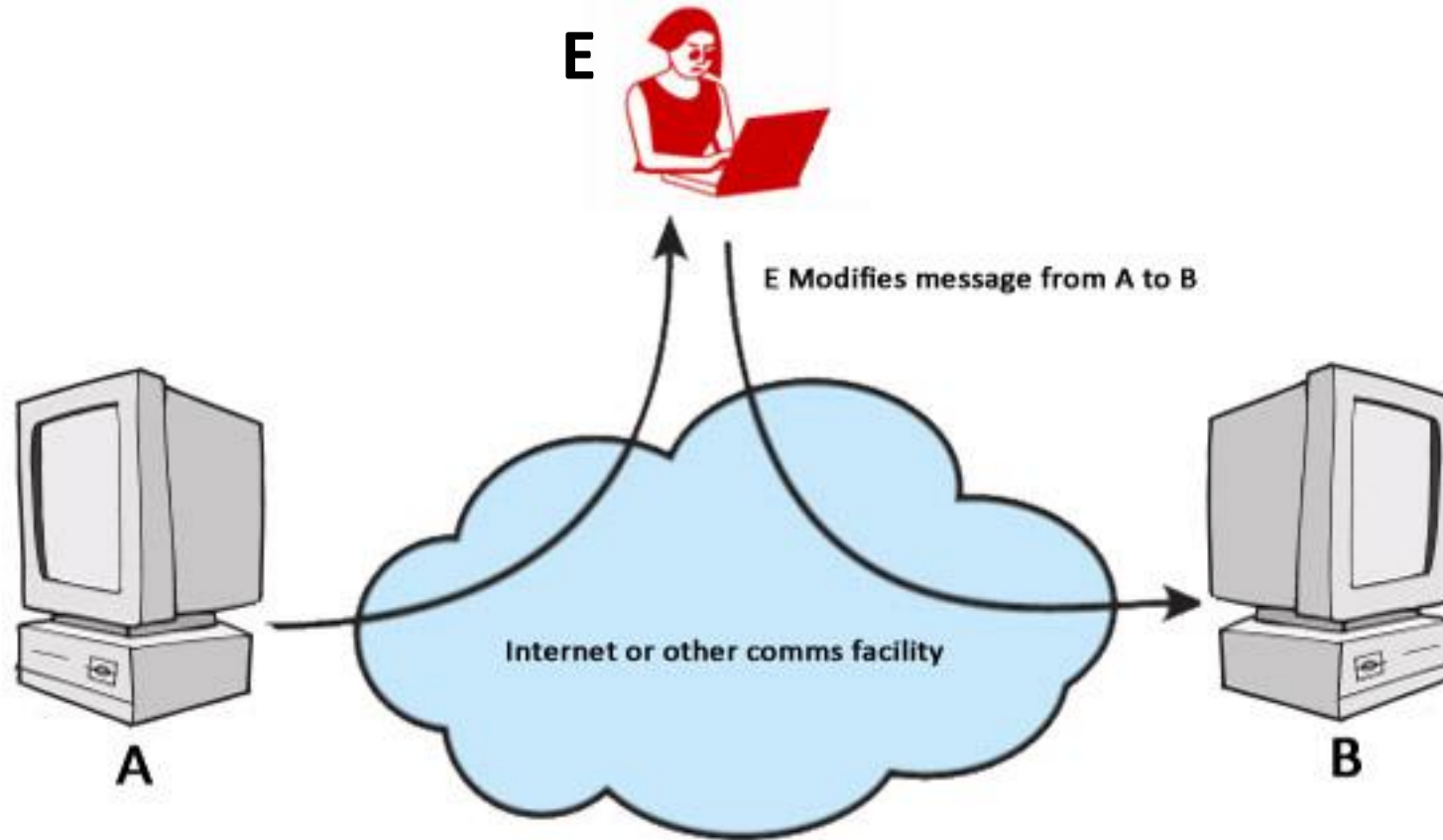
Replay – Active Attack



Key Security Concepts



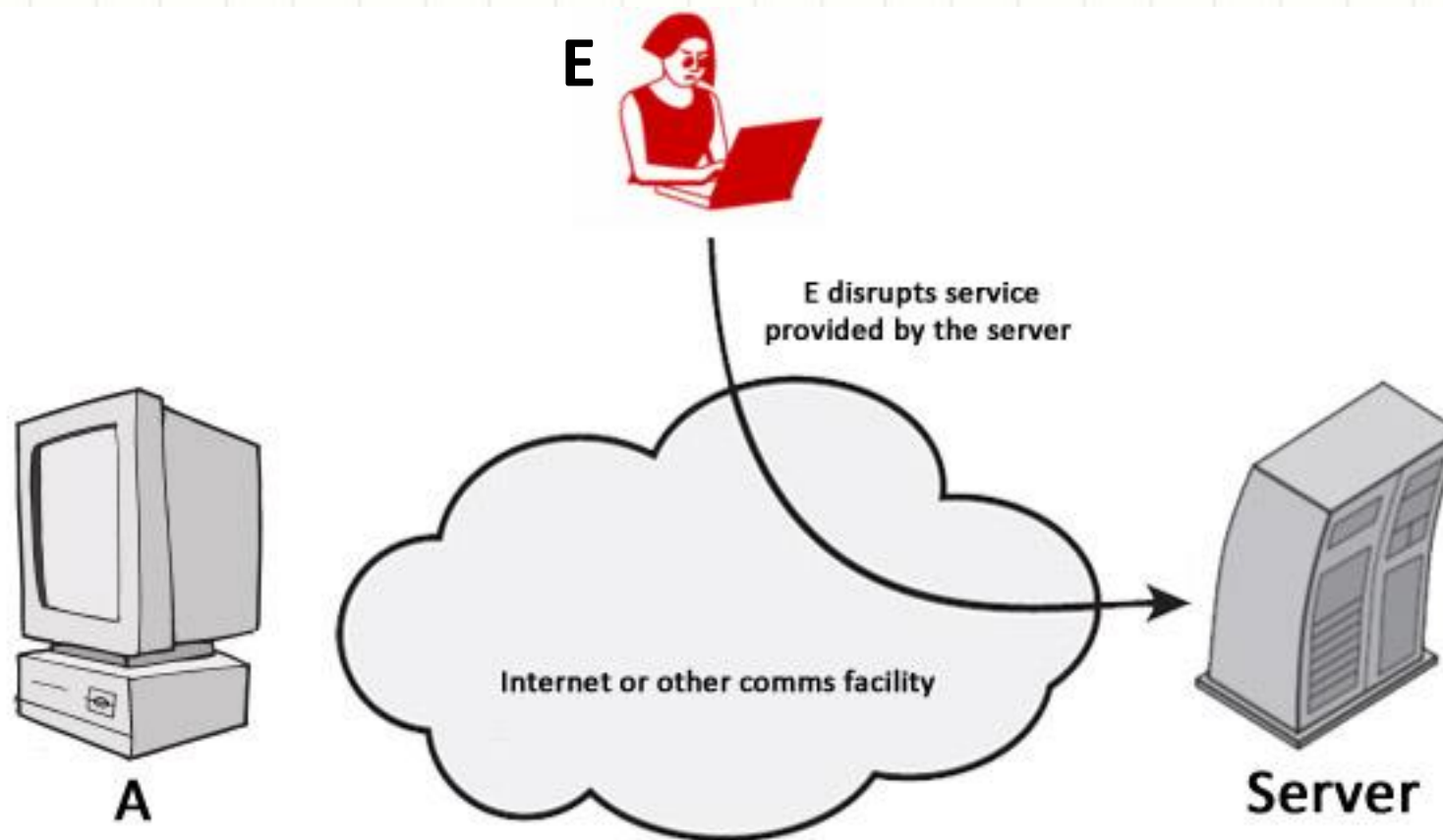
Modification – Active Attack



Key Security Concepts



Denial of service – Active Attack



Key Security Concepts



Defining a Security Service

- ❑ ITU-T X.800 is a service that is provided by a protocol layer of communicating systems and that ensures adequate security of the systems or of data transfers
- ❑ IETF RFC 2828 is a processing or communication service that is provided by a system to give a specific kind of protection to system resources
- ❑ Security services implement security policies and are implemented by security mechanisms

Key Security Concepts



Security Services

- ☐ **Authentication** assure that the communicating entity is the one that it claims to be
- ☐ **Access Control** prevent unauthorized use of a resource
- ☐ **Data Confidentiality** protect data from unauthorized disclosure
- ☐ **Data Integrity** assure data received are exactly as sent by authorized entity
- ☐ **Nonrepudiation** protect against denial of one entity involved in communications of having participated in communications
- ☐ **Availability** system is accessible and usable on demand by authorized users according to intended goal

Key Security Concepts



Security Mechanisms

- ❑ Techniques designed to prevent, detect or recover from attacks
- ❑ No single mechanism can provide all services
- ❑ Cryptographic techniques are most common
- ❑ Specific security mechanisms from ITU-T X.800:
 - ❑ Encipherment, digital signature, access control, data integrity, authentication exchange, traffic padding, routing control, notarization
- ❑ Pervasive security mechanisms from ITU-T X.800:
 - ❑ Trusted functionality, security label, event detection, security audit trail, security recovery

Key Security Concepts



Security Services and Mechanisms

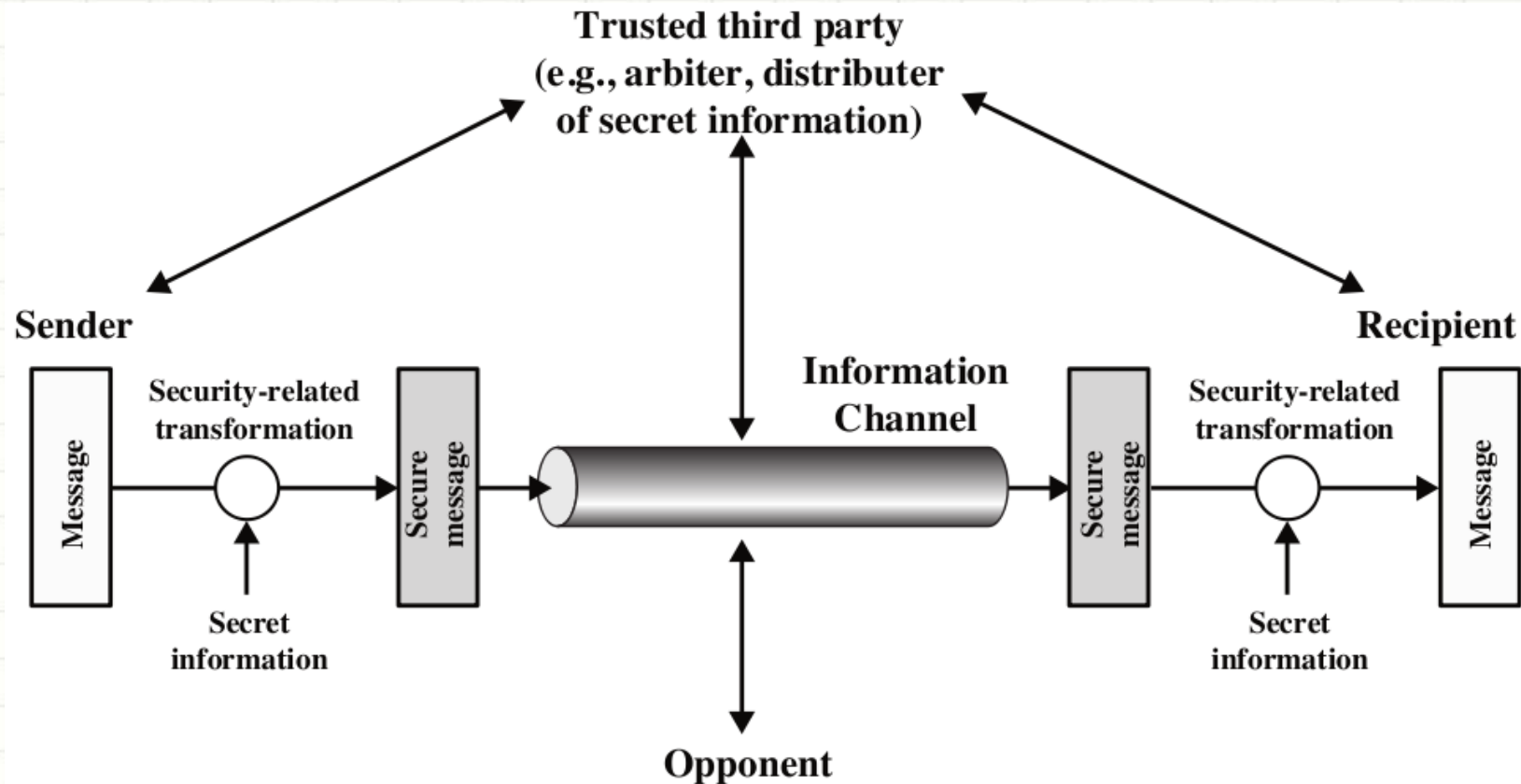
Service	Mechanism							
	Enciph- erment	Digital signature	Access control	Data integrity	Authenti- cation exchange	Traffic padding	Routing control	Notari- zation
Peer entity authentication	Y	Y			Y			
Data origin authentication	Y	Y						
Access control			Y					
Confidentiality	Y						Y	
Traffic flow confidentiality	Y					Y	Y	
Data integrity	Y	Y		Y				
Nonrepudiation		Y		Y				Y
Availability				Y	Y			

Key Security Concepts



Network Security Model

- ❑ Model of a system that captures many aspects of security



Key Security Concepts



Network Security Model

- ❑ Using this model requires us to:
 - ❑ design a suitable algorithm for the security transformation
 - ❑ generate the secret information (keys) used by the algorithm
 - ❑ develop methods to distribute and share the secret information
 - ❑ specify a protocol enabling the principals to use the transformation and secret information for a security service

Key Security Concepts



- ❑ Alice and Bob are the two most famous persons in computer security
- ❑ They are used everywhere



- ❑ Alice and Bob want to communicate “securely”
- ❑ Trudy (intruder) may interrupt, intercept, modify, fabricate and so on, to disrupt their communications

Key Security Concepts



Who might Alice and Bob be?

- ☐ Well, real-life Alice(s) and Bob(s)!
- ☐ Web browser/server for electronic transactions (e.g., on-line purchases)
- ☐ On-line banking client/server
- ☐ DNS servers
- ☐ Routers exchanging routing table updates
- ☐ Other examples?

Key Security Concepts



Question: What could Trudy do in this case?

Answer: Unfortunately, a lot!

- ☐ **Interruption:** Somehow disrupt the service being provided to Alice and Bob
- ☐ **Interception:** Eavesdrop on communication meant to be private or confidential
- ☐ **Modification:** Tamper with information or resources
- ☐ **Fabrication:** Counterfeit information or resources, insert new services into the system

Key Security Concepts



How can we protect ourselves from these attacks?

- ☐ Interruption attacks:
 - ☐ Firewalls, replication, backups, hardware appliances
- ☐ Interception attacks:
 - ☐ Encryption, traffic padding
- ☐ Modification attacks:
 - ☐ Encryption, traffic padding, backups, messaging techniques (checksums, sequence numbers, digests, authentication codes)
- ☐ Fabrication attacks:
 - ☐ Authentication and authorization, firewalls, digital signatures

Key Security Concepts



- ☐ **Hackers** are vandals that break into computer systems
- ☐ These criminals call themselves hackers, and that is how they got the name
- ☐ But they do not deserve the name
- ☐ True hackers are master programmers, incorruptibly honest, unmotivated by money, and careful not to harm anyone
- ☐ The criminals termed "hackers" are not brilliant and accomplished
- ☐ It is really too bad that they not only steal money, people's time, and worse, but they've also stolen a beautiful word that had been used to describe some remarkable and wonderful people
- ☐ A name for a bad guy is **intruder**, **bad guy**, and **impostor**

Key Security Concepts



Hacker Categories

- ❑ **Hacker** - Cleaver programmer
- ❑ **Cracker** - Illegal personnel
- ❑ **Script Kiddies** – A starting hacker that may not target a specific system (rely on tools written by others)
- ❑ **White Hat Hackers** - Good guys that are very knowledgeable and are hired to find a vulnerability in a network (write own software)
- ❑ **Black Hat Hackers** - Bad guys that desire to cause harm to a specific system (write own software)
- ❑ **Cyber Terrorists** - Motivated by political, religious, or philosophical agenda

Key Security Concepts



- ❑ **Security** is a policy, **Protection** is a mechanism
- ❑ Protection mechanisms implement security policies
- ❑ **Vulnerability** is a weakness that can allow an attacker to cause problems
- ❑ **Exploit** is an actual incident of taking advantage of a vulnerability

Key Security Concepts



- ❑ **Virus** is a potentially damaging computer program (code), can spread and damage files. It attaches itself to programs, disks, or memory to propagate itself
- ❑ **Worm** copies itself repeatedly, using up resources and possibly shutting down computer or network
- ❑ **Trojan horse** hides within or looks like legitimate program until triggered, does not replicate itself on other computers
- ❑ **Spyware** is program placed on computer without user's knowledge, collects personal information
- ❑ **Adware** is a program that displays online advertisements
- ❑ **Spam** is unsolicited e-mail message sent to many recipients

Key Security Concepts



10 Immutable Laws of Security

- 1) If a bad guy can persuade you to run his program on your computer, it's not your computer anymore
- 2) If a bad guy can alter the operating system on your computer, it's not your computer anymore
- 3) If a bad guy has unrestricted physical access to your computer, it's not your computer anymore
- 4) If you allow a bad guy to upload programs to your website, it's not your website any more
- 5) Weak passwords trump strong security

Key Security Concepts



- 6) A computer is only as secure as the administrator is trustworthy
- 7) Encrypted data is only as secure as the decryption key
- 8) An out of date virus scanner is only marginally better than no virus scanner at all
- 9) Absolute anonymity isn't practical, in real life or on the Web
- 10) Technology is not a panacea

References



- ❑ Security Focus

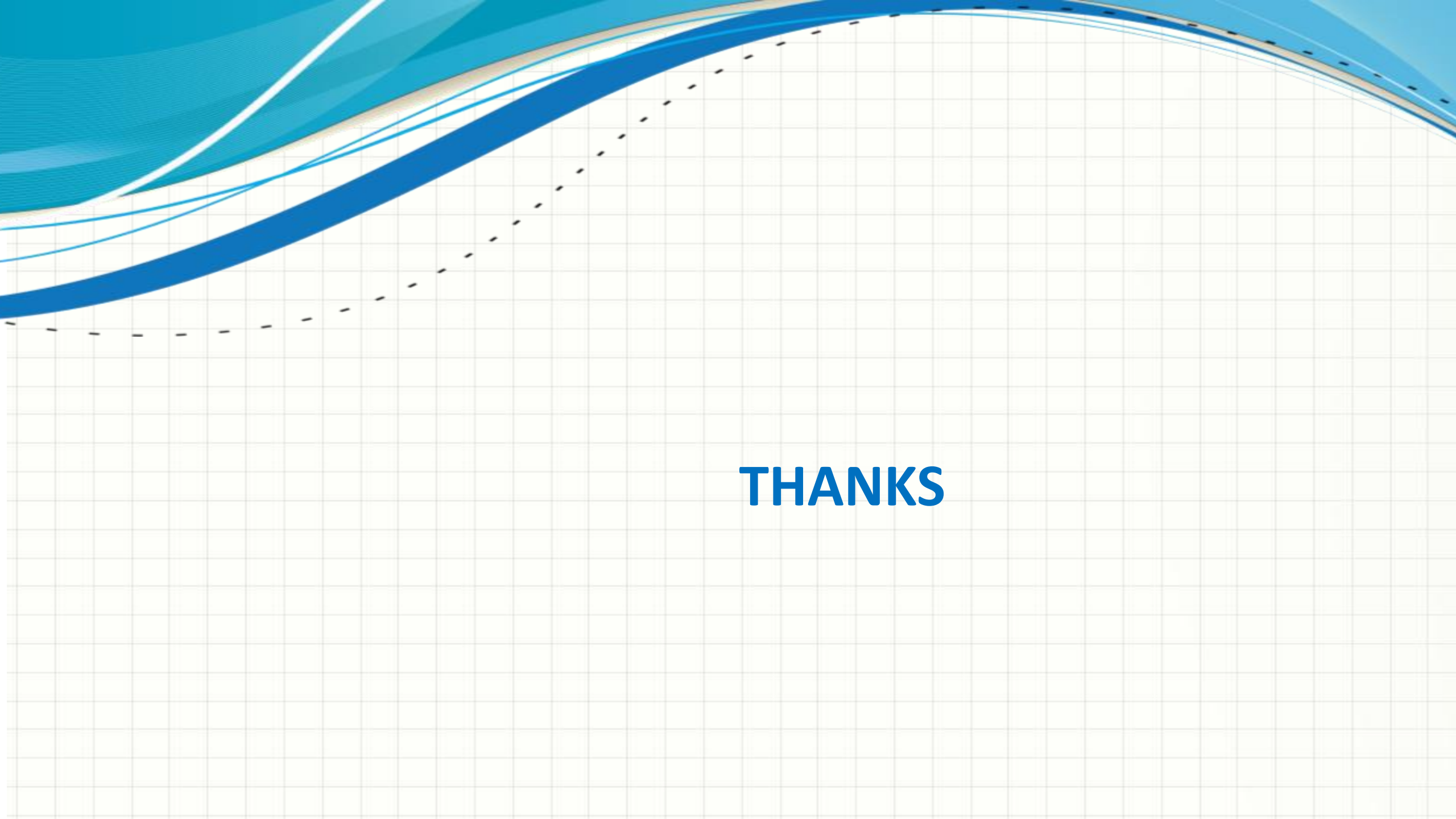
<http://www.securityfocus.com/>

- ❑ SANS Institute

<http://sans.org/>

- ❑ Cyberoam Animated Movie

<http://www.cyberoam.com/videos/animatedpresentation/>



THANKS